

Beyond the Hype: Empirical Analysis of Matter Standard's Security and Privacy

Andrew Losty
andrew.losty.23@ucl.ac.uk
University College London
United Kingdom

Tianrui Hu
hu.tian@northeastern.edu
Northeastern University
United States

Daniel J. Dubois
d.dubois@northeastern.edu
Northeastern University
United States

Narmeen Shafqat
narmeen_shafqat@mcs.edu.pk
NUST
Pakistan

Aanjhan Ranganathan
aanjhan@northeastern.edu
Northeastern University
United States

David Choffnes
choffnes@ccs.neu.edu
Northeastern University
United States

Anna Maria Mandalari
a.mandalari@ucl.ac.uk
University College London
United Kingdom

ABSTRACT

The rapid growth of the Internet of Things (IoT) has created fragmented smart home ecosystems, with platforms such as Apple Home, Google Home, and Samsung SmartThings historically relying on proprietary protocols and device-specific implementations that limited interoperability. The Matter standard defines a common, secure application-layer framework enabling cross-platform interoperability for Internet of Things (IoT) devices. It is developed under the Connectivity Standards Alliance (CSA), an industry consortium comprising more than 860 member organizations. This study empirically analyzes Matter and non-Matter ecosystems, focusing on security and privacy. We evaluate 25 Matter devices and 14 non-Matter devices with comparable functionality, examining network traffic during commissioning, device control, and data transmission. Our evaluation shows that Matter improves security and privacy through AES-128-CCM encryption, device attestation, and secure commissioning. Its local-first design further reduces cloud dependency and limits data exposure.

However, we identify several risks. Persistent multicast DNS broadcasts reveal detailed device metadata, and rotating key identifiers are inconsistently implemented, with some devices failing to renew keys for extended periods. We also observe ecosystem-specific differences in commissioning behavior. In addition, many devices maintain persistent connections to vendor or third-party cloud services. Firmware maintenance is inconsistent, as most devices in our study run early versions of Matter and do not receive updates over the observation period. Finally, traffic patterns in encrypted unicast communication can still reveal device types and user activities to an in-network adversary.

CCS CONCEPTS

• **Security and privacy** → **Security protocols**; • **Networks** → **Home networks**; **Application layer protocols**; **Network measurement**.

KEYWORDS

Internet of Things, Matter Standard, Security, Privacy, Network Traffic Analysis

ACM Reference Format:

Andrew Losty, Tianrui Hu, Daniel J. Dubois, Narmeen Shafqat, Aanjhan Ranganathan, David Choffnes, and Anna Maria Mandalari. 2026. Beyond the Hype: Empirical Analysis of Matter Standard's Security and Privacy. In *Proceedings of the 2026 ACM Internet Measurement Conference (IMC '26)*, October 12–16, 2026, Karlsruhe, Germany. ACM, New York, NY, USA, 14 pages. <https://doi.org/10.1145/3777912.3809142>

1 INTRODUCTION

The architecture of smart home Internet of Things (IoT) infrastructure may be undergoing a profound and fundamental transformation. Historically, smart home IoT platforms evolved independently as manufacturers sought to differentiate their products through proprietary security, privacy implementations and operational features. This resulted in a fragmented smart home ecosystem, in which competing platforms such as Apple Home, Google Home, Samsung SmartThings, and Amazon Alexa relied on vendor-specific implementations that severely limited interoperability.

To address these limitations, major IoT stakeholders collaboratively developed the Matter standard [4]. This effort culminated in the release of the Matter specification in October 2022. The specification enhances interoperability by defining a unified communication protocol that enables seamless interaction among devices from different manufacturers. Furthermore, it strengthens security by incorporating mandatory encryption, standardized authentication mechanisms, and uniform commissioning procedures.

In this paper, our main goal is to study how Matter behaves in real consumer environments by analyzing the privacy and security properties of 25 Matter devices across four major smart home ecosystems, and comparing them with 14 non-Matter devices from both the same manufacturers and other vendors offering equivalent functionality. We also study how ecosystem behavior, Matter/non-Matter hybrid-stack operation, and exposure to realistic adversarial conditions influence the privacy and security guarantees that Matter aims to provide. More specifically, we investigate the following four research questions.

RQ1: Do Matter-enabled devices offer improved security and privacy compared to similar non-Matter devices? The Matter standard provides a unified and secure communication framework for smart



This work is licensed under a Creative Commons Attribution International 4.0 License.

home devices. Does its adoption lead to tangible improvements in privacy and security compared to legacy and proprietary protocols?

RQ2: Do ecosystem-specific interpretations of the Matter standard introduce measurable vulnerabilities in device behavior? While Matter provides a common standard, its implementation may vary across different manufacturers and ecosystems. How do these variations impact device behavior and vulnerability exposure?

RQ3: What are the implications of supporting both the Matter protocol and vendor-specific legacy protocols on IoT devices? Many smart devices support multiple communication stacks to maintain compatibility with other ecosystems. Does the coexistence of multiple stacks on a single device undermine the security benefits that Matter aims to provide?

RQ4: How resilient are Matter devices to realistic adversarial actions, such as unauthorized connection attempts and traffic-based inference? In particular, can an adversary, either on the local network (such as a malicious guest or compromised controller) or within wireless proximity of the device, gain unauthorized control or infer device type, vendor, or user actions from encrypted network traffic in a typical smart home deployment?

The contributions of our research are as follows:

- We conduct the first systematic evaluation of Matter’s real-world security and privacy impact, analyzing 25 Matter devices and 14 non-Matter counterparts across 4 leading smart home ecosystems, revealing that Matter improves security over non-Matter devices through authenticated and encrypted local control, while simultaneously introducing new privacy risks by broadcasting richer metadata (Section 4).
- We evaluate Matter devices against the specification and identify several ecosystem-dependent deviations, including inconsistent adoption of IPv6 privacy mechanisms, infrequent updates to newer Matter specification versions, and diverse service advertisement formats that weaken privacy guarantees (Section 5).
- We show that many Matter-enabled devices continue to operate vendor-specific legacy protocols in parallel with Matter, and that this dual-stack behavior maintains cloud connectivity even in local-mode configurations, increasing metadata exposure and enabling vendor or third-party tracking (Section 6).
- We find that Matter’s communication patterns enable fine-grained passive inference: even when payloads are encrypted, service advertisements and traffic sequences allow attackers to classify device types, identify vendor families, and infer user actions with high accuracy (Section 7).

Our research delivers insights to help manufacturers and standardization and regulatory bodies mitigate privacy and security risks in smart homes. To facilitate additional research into this, we make our IoT measurement, analysis code and data publicly available at https://github.com/SafeNetIoT/matter_sec_privacy.

2 BACKGROUND

Prior research shows that home IoT ecosystems exhibit persistent security weaknesses, including weak/absent authentication [16, 26], unencrypted or poorly protected communication channels [16, 39], insecure firmware [1, 16], and over-privileged or inconsistently

enforced APIs [16]. These vulnerabilities expose devices to eavesdropping, spoofing, unauthorized control, and large-scale compromise [1, 2, 16, 26, 39].

IoT devices routinely collect data [22], are vulnerable to cross-device tracking, behavioral profiling, and ad-targeting [30], often have globally routable IPv6 addresses that increase discoverability and attack surfaces [21], expose sensitive metadata such as device type and usage patterns [28, 33], and generate non-essential third-party traffic that leaks further information [14].

To assess whether Matter addresses these longstanding weaknesses, we next outline the core components and security properties of the standard and compare them with common legacy IoT protocols.

2.1 Matter Standard Overview

Matter, formerly recognized as CHIP (Connected Home over IP), is a unified smart home connectivity standard developed by the Connectivity Standard Alliance (CSA), an industry consortium comprising more than 860 member organizations as of October 2025. [8]

Launched in October 2022, Matter aims to enhance the integration of IoT devices across ecosystems while providing strong, standardized security and privacy guarantees.

2.1.1 Matter Ecosystem Components. The Matter ecosystem is divided into controllers and devices. Matter controllers manage and coordinate Matter-enabled smart home devices, and are often implemented in leading smart speakers and hubs such as the Apple HomePod [3], Amazon Echo [18], and Samsung SmartThings Station [36]. Matter devices support the functionality, security, and operational communications defined by the Matter protocol. Each device has a QR code/ numeric string for commissioning and a Device Attestation Certificate (DAC) for authentication. Matter organizes devices into fabrics, which are administrative domains built around a shared root of trust and access control configuration. Each Matter fabric is identified by a unique 64-bit Fabric ID, and each node on that fabric is assigned a persistent 64-bit Node ID used for operational communication. Matter operates over Ethernet (IEEE 802.3), Wi-Fi (IEEE 802.11), and Thread (IEEE 802.15.4), an IP-based mesh networking protocol [5]. Non-Matter devices such as Zigbee or Z-Wave can be integrated into a Matter ecosystem via a Matter bridge [6].

2.1.2 Matter’s Security Provisions. Commissioning begins when a Matter device (*Commissionee*) advertises itself via Bluetooth Low Energy (BLE) or DNS Service Discovery (DNS-SD), or when its QR code is scanned to initiate setup. Once commissioning starts, the *Commissioner* (i.e., a function of the controller typically offered through its companion app) establishes a Password Authenticated Session Establishment (PASE) session with the Matter device to securely exchange setup credentials. During this process, the Commissioner validates the device’s Device Attestation Certificate (DAC) and verifies the certification chain either via the Distributed Compliance Ledger (DCL), a blockchain-based registry maintained by the Connectivity Standards Alliance (CSA), or locally stored Product Attestation Authority (PAA) root certificates, though specific implementations vary by vendor [7].

Table 1: Matter vs Non-Matter Device Communication.

Comm	Aspects	Non-Matter Devices	Matter Devices
Local	Protocols	Varies, often proprietary	UDP/TCP port 5540*
	Encryption	Varies, often no encryption	AES-128-CCM AES-256-CCM
	Service Discovery	Various local protocols	UDP port 5353 mDNS
	Attestation	Proprietary	Certificate x.509.3
Internet	Destination	Dependent for operation and control	Not dependent for operation and control

* Port 5540 is IANA-registered for Matter; other ports are permitted by the specification.

Upon successful authentication, the Commissioner provides the device with essential credentials and information, including the Root Certificate Authority (CA) Certificate, Node Operational Certificate (NOC), network details, and Access Control List (ACL). The system then transitions to Certificate Authenticated Session Establishment (CASE), which negotiates symmetric encryption keys for operational messages. Subsequently, when a command is received, the node verifies the sender's NOC using the Root CA Certificate and consults the ACL to confirm that the sender is authorized to perform the requested action.

Matter supports multi-admin, enabling devices to be securely added to multiple controllers. While the QR code is used solely for the initial pairing, subsequent commissioning with other controllers is facilitated by a time-limited pairing code generated by the first controller's app. Additionally, all over-the-air firmware updates are digitally signed, ensuring their integrity and authenticity.

2.1.3 Matter's Privacy Provisions. Matter introduces several mechanisms to strengthen privacy, such as per-fabric random node identifiers, optional (but recommended) use of IPv6 address randomization, encrypted operational messaging, and privacy-preserving session establishment. However, the practical effectiveness of these protections depends on device and ecosystem implementations, and Matter does not regulate out-of-band cloud interactions (e.g., telemetric reporting) performed by vendor-specific services.

2.1.4 Matter Certification Process. CSA certifies Matter devices for protocol compliance, interoperability, and security. Certified devices must implement mandatory features, such as device attestation and secure commissioning, and are authorized to display the Matter logo.

2.2 Matter vs. Legacy Protocols

Table 1 compares Matter with common non-Matter communication approaches, highlighting key advantages in security and device attestation. Non-Matter devices typically rely on proprietary protocols that vary widely in design goals, security guarantees, and interoperability. In contrast, Matter defines a unified protocol suite

operating over TCP/UDP port 5540 and incorporates encryption, device attestation, and secure onboarding.

Non-Matter IoT devices often use cloud-centric architectures. By routing interactions through vendor servers, they may increase the risk of redirection, observation, and manipulation by parties outside the LAN. Matter, in contrast, uses a local-first design, enabling devices to operate within the local network without requiring Internet connectivity. Table 1 illustrates Matter's improvements in standardization, security, and local management and control.

3 EXPERIMENTAL SETUP

This section first defines the threat model, outlining potential adversary capabilities and security risks, and then describes the testbed, detailing the devices, controllers, and methodology used to evaluate Matter and non-Matter smart home systems.

3.1 Threat Model

We consider adversaries with local network proximity enabling passive wireless access (e.g., Wi-Fi, Thread, or BLE), capable of eavesdropping, traffic capture, and limited active interaction during commissioning and normal operation. Adversaries are assumed not to possess the ability to decrypt operational communications.

Privacy Leakage and Fingerprinting. Devices may expose persistent identifiers and excessive metadata during both pre- and post-commissioning phases. Adversaries can exploit such information to perform device fingerprinting, infer user behavior, and facilitate cross-network tracking.

Traffic Analysis and Behavioral Inference. Deterministic or predictable communication patterns can facilitate traffic analysis, allowing adversaries to infer device states and user activities even when payloads are encrypted.

Firmware and Update Vulnerabilities. Delayed or absent firmware updates increase exposure to new and known vulnerabilities, which adversaries may exploit to compromise device integrity or gain persistent access.

Protocol Compliance and Operational Risks. Deviation from current specifications and recommended security practices may introduce protocol-level weaknesses, potentially enabling unauthorized access, replay attacks, or passive eavesdropping during commissioning and routine operation.

3.2 Testbed

Our study uses a testbed of 39 smart home devices (Table 2) acquired between 2023 and 2025, all commonly available in the US and/or UK markets:

- 25 Matter devices: Smart plugs, bulbs, and bridges from multiple manufacturers, representing typical consumer-grade Matter-enabled devices.
- 14 legacy (non-Matter) devices: Selected products from the same manufacturers as the Matter devices, along with equivalent models from other vendors, to provide a baseline for comparison.
- 4 Matter controllers: Apple HomePod Mini, Amazon Echo (4th Generation), SmartThings Aeotec Smart Home, and Google Home, representing popular ecosystem controllers.

- 2 mobile devices: An iPhone Xs running iOS 17 and a Pixel 7 running Android 13, each using the corresponding companion apps required for device and controller management. Both phones had automatic app updates enabled, ensuring that the latest available versions of all companion apps were used throughout the study.

To enable a direct comparison between Matter and non-Matter devices, this study focuses exclusively on Ethernet/Wi-Fi devices, excluding Matter devices that operate over Thread 802.15.4 mesh networks. By concentrating on Wi-Fi devices, the study establishes an empirical baseline that can inform and guide future evaluations of Matter and non-Matter device performance across different network technologies.

Device selection was guided by market popularity and ecosystem coverage. We selected the most common Matter devices available on major retail platforms (e.g., Amazon US and Amazon UK), using their popularity rankings to identify widely deployed models. Our choices also aimed to capture a diverse set of configurations, including (i) Matter devices with non-Matter counterparts from the same manufacturer, (ii) different device categories from the same vendor (e.g., plug vs. bulb), and (iii) devices from different manufacturers that rely on the same ecosystem or companion app. Table 2 lists each device and its companion app.

4 MATTER VS. LEGACY IOT DEVICES

This section answers RQ1: “Do Matter-enabled devices offer improved security and privacy compared to similar non-Matter devices?” Specifically, it evaluates whether Matter delivers on its promise of enhanced security and privacy in local network communication compared to legacy or proprietary IoT protocols used by similar non-Matter devices.

Methodology. Prior to testing, all devices were reset to factory defaults. To systematically evaluate security and privacy properties across Matter and non-Matter IoT ecosystems, we first captured BLE advertisements from devices in the uncommissioned state using a Nordic nRF Sniffer. We then onboard all 39 devices. Matter devices were paired by scanning their QR codes or manually entering their unique 11-digit PINs in the ecosystem app, while non-Matter devices were onboarded via their respective manufacturer apps and subsequently integrated into the ecosystem app. Wi-Fi traffic was captured using tcpdump during device boot, idle periods, and active interactions, following established methodologies from prior work [20]. Captured traffic was analyzed in Wireshark using custom display filters. Our analysis focused on key aspects of communication: unicast traffic (device-to-device), multicast traffic (used for service discovery), and network-level identifiers such as IPv6 addresses.

Unicast Traffic. Unicast traffic in non-Matter devices is often unencrypted and unauthenticated, making it vulnerable to interception by attackers on the local network, such as via a compromised router or ARP spoofing. In contrast, Matter devices use authenticated, end-to-end encrypted communication, as shown in Table 3. For example, TP-Link’s legacy Kasa bulb transmits unencrypted packets exposing device identifiers and geolocation, whereas the Matter-enabled TP-Link Tapo bulb protects sensitive information in transit.

Table 2: Non-Matter / Matter Device Set.

	Devices	Device App
Non-Matter Devices		
Bulbs	TP-Link Kasa bulb	TP-Link Kasa
	Sengled bulb	Sengled Home
	Gosund bulb	Gosund, Tuya
	Wiz bulb	WiZ Connected
	Smartlife bulb	Smartlife
	Yeelight bulb	Yeelight
	Govee LED strip	Govee Home
	Magic home strip	Magic Home
Plugs	TP-Link Kasa plug	TP-Link Kasa
	Meross plug	Meross
	Wemo plug	Wemo
	Amazon plug	Alexa
Misc	Meross door opener	Meross
	August lock	August
Matter Devices		
Bulbs	TP-Link Tapo bulb*	TP-Link Tapo
	Sengled bulb*	None
	Linkind bulb	AiDot
	Orein bulb	
	Consciot bulb	
	Govee LED strip	Govee Home
Plugs	TP-Link Tapo plug	TP-Link Tapo
	Meross plug	Meross
	Eightree plug	Smartlife
	Sengled plug	None
	Sailsco plug	None
	Xenon plug	None
	Moes plug	Tuya
	Tuya plug	
	Linkind plug	AiDot
	Cync plug	Cync
	Leviton plug *	My Leviton
	UseLink plug	None
Bridges	Aqara bridge *	Aqara
	Aqara bridge M2 *	
	Switchbot bridge *	Switchbot
	Philips bridge *	Philips Hue
	Smartlife bridge	Smartlife
	Third Reality Bridge	Third Reality
	Meross bridge	Meross
Matter Compatible Controllers		
Controllers	Apple Homepod mini	Home
	Google Nest mini	Google Home
	Amazon Echo	Alexa
	Aeotec SmartThings	SmartThings

* Device updated to support Matter via firmware update

Multicast Traffic. Prior work [16] shows that many IoT devices rely on multicast protocols, such as mDNS, for service discovery, often broadcasting plaintext metadata on the local network. We observe that Matter adoption increases this exposure: 58% (15 of 25) of Matter devices broadcast metadata over port 5353, compared to 14% (2

Table 3: Information Exposure in Local Communication of Matter and Non-Matter IoT Devices.

Devices		Unicast Traffic	Multicast Traffic
Non-Matter Devices			
Bulbs	Govee LED strip	Encrypted (proprietary)	No leaks
	Remaining	Unencrypted/No Auth	
Plugs	TP-Link Kasa plug		Dev info, location,
	Meross plug	No Traffic	No leaks
	Wemo plug	Unencrypted	
	Amazon plug	Encrypted (proprietary)	
Misc	August lock		
	Meross door	No Traffic	
Matter Devices			
Bulbs	TP-Link bulb	Encrypted, Authenticated	VID, PID, DT, DN
	Linkind, Orein, Consciot		SD
	Sengled, Govee		No leaks
Plugs	Tapo, Meross, Sailsco, Moes,		VID, PID, DT, DN
	Tuya, Leviton*, UseLink		VID, PID, DT
	Cync		VID, PID
	Eighttree, Linkind		SD
	Other Plugs		No leaks
Bridges	Meross		VID, PID, DT
	Aqara, Aqara M2 Switchbot, Philips Smartlife		No leaks
	Third Reality		

VID = Vendor Identifier, PID = Product Identifier, DT = Device Type, DN = Device name, SD = Session Duration, * = Device updated to support Matter via firmware update.

of 14) of non-Matter devices. These broadcasts may include VID (vendor identifier), PID (product model), DT (device class), DN (device name), RI (rotating identifier), and PH (pairing hints). Matter devices continue advertising this information after commissioning, enabling adversaries on the same local network to perform passive device enumeration, fine-grained fingerprinting, and traffic correlation, and further facilitating targeted exploitation based on identified device types and vendors.

Matter relies on mDNS for local discovery and multi-admin interoperability, which results in periodic broadcast of device and service metadata at the network level. Consequently, a privacy–security tradeoff emerges: Matter strengthens confidentiality of *unicast communication content* via authenticated encryption, but reduces anonymity of *device identity and presence* by exposing broadcast metadata.

mDNS advertisement intervals for Matter devices are implementation dependent and not defined in the relevant RFCs or the Matter

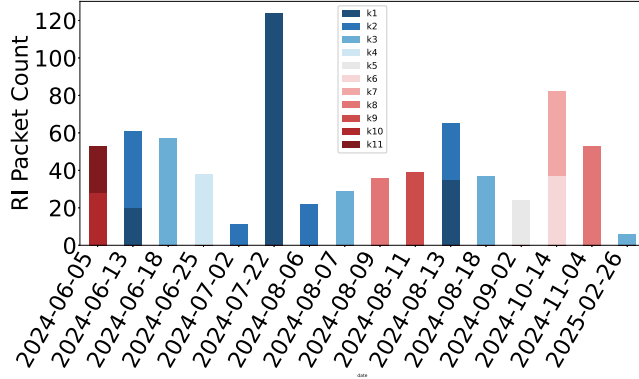
specification. Empirical observations show rapid burst announcements during commissioning, followed by steady-state intervals of roughly 10–50 s in some implementations (e.g., Meross, Sengled), while others extend re-advertisement periods to approximately 400–1000 s (e.g., Eighttree).

Rotating Device ID. Many non-Matter IoT devices use mDNS or BLE advertisements during initial setup to announce themselves using static identifiers, which can enable device tracking and facilitate spoofing attacks. Matter devices mitigate this risk by supporting Rotating Device Identifiers (RDIs), which may be used in both uncommissioned and commissioned states within mDNS and BLE advertisements. According to the Matter 1.0 specification [Section 5.4.2.4.5], RDIs “rotate at pre-defined moments” based on a lifetime counter incremented with each advertising session rather than a fixed time interval, thereby enhancing privacy and reducing susceptibility to device fingerprinting and long-term tracking.

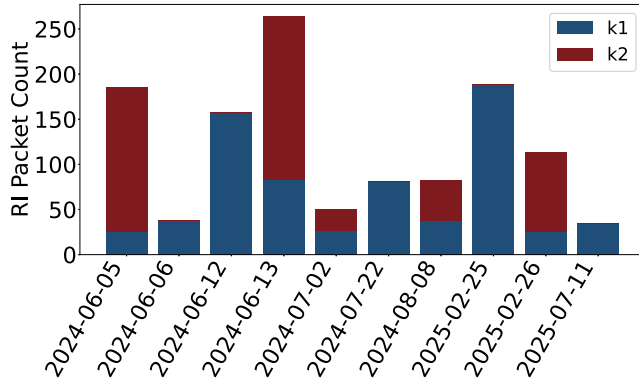
We conduct a longitudinal study from June 2024 to Nov 2025 to characterize Rotating Device ID patterns and assess trackability and fingerprinting risks. We find that rotation behavior varies significantly across manufacturers. As shown in Figure 1a, the Linkind smart plug exhibits relatively frequent rotation, generating 11 distinct keys over 266 days (on average once every 24 days), whereas the Tuya plug in Figure 1b uses only two keys over 401 days with an average interval of over 200 days, indicating severely limited rotation and extended key reuse. In contrast, the Cync Matter plug retained a single identifier over the entire 263-day observation period (Figure 1c). The Rotating Device Identifier (RDI) is used during commissionable node discovery. However, Matter devices, including the Linkind, Tuya and Cyn plugs, continue to advertise RDI after commissioning. These results demonstrate substantial variation in real-world RDI implementations, with several vendors undermining Matter’s intended privacy benefits through prolonged key reuse, and extended commissioning window.

IPv6 addressing. Although non-Matter smart home IoT devices have historically used IPv4 for local communication, Matter is designed to operate primarily over IPv6. This makes Matter devices, in general, also ready to be deployed in dual stack or IPv6-only home networks. We observe, however, that many Matter devices commonly employ EUI-64–derived IPv6 interface identifiers. This creates a fixed relationship between a device’s MAC address and its IPv6 address, introducing privacy risks by enabling stable device tracking and fingerprinting [16, 21]. Such use of EUI-64 identifiers contradicts guidance in the CSA Matter Security and Privacy Fundamentals white paper [10] and in RFC 7721 [9]. This behavior is also common among non-Matter devices that support IPv6, as reported in prior work [21].

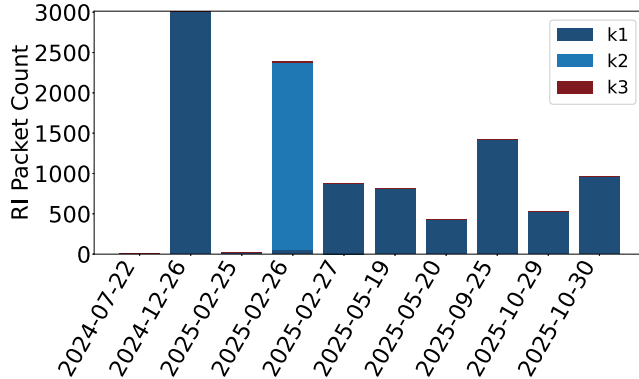
In our study, we permit only single-stack IPv4 Internet connectivity. As a result, all observed Matter devices used non-routable link-local or unique-local IPv6 addresses—limiting immediate exploitability. However, the Matter specification does not preclude the use of globally routable IPv6 addresses when devices are deployed in networks with Internet IPv6 connectivity. For this reason, Matter devices should adopt randomized interface identifiers, such as those specified in RFC 7217 [17], to reduce long-term device tracking.



(a) Linkind Matter Plug: 11 rotations over 266 days



(b) Tuya Matter Plug: 2 rotations over 401 days



(c) Cync Matter Plug: Single key for 263 days

Figure 1: Comparison of RDI implementation across vendors.

Key Findings. The adoption of Matter marks a clear step forward in secure IoT communication through features such as device authentication, end-to-end encryption, secure standardized firmware update mechanisms, and encrypted unicast traffic. These mechanisms eliminate common weaknesses found in legacy IoT protocols and enforce a consistent security baseline across vendors. However, our results show that privacy protections are considerably weaker in practice. Matter devices expose substantially more metadata over mDNS than their non-Matter counterparts, often revealing

Table 4: Comparison of Matter implementations across major smart home bridges using a test Matter device.

Parameter	Smart Things	Apple Home	Google Home	Amazon Alexa
Pop-Up Warning	Not a Certified Matter Device			Not Matter compatible
Port	Random		5540	5541
Connection	Mobile			Direct
Logs	Concise			Verbose
Control	Supports on/off	Supports On/Off and color change		

vendor, product, and device-type information, and in many cases user-assigned names. RDI rotation is inconsistently implemented, with several devices reusing identifiers for months, and many devices employ EUI-64-derived IPv6 interface identifiers that enable persistent device tracking. Overall, Matter strengthens the confidentiality of unicast device communication, but increases device identifiability and long-term trackability on local networks due to frequent unencrypted multicast communication.

5 MATTER IMPLEMENTATIONS

This section answers RQ2: “Do ecosystem-specific interpretations of the Matter standard introduce measurable vulnerabilities in device behavior?” Although Matter aims to unify smart home connectivity, vendors retain considerable freedom in how they implement the standard. Specifically, this section examines how major ecosystem providers differ in their Matter integrations and whether these variations affect device behavior or inadvertently introduce new security and privacy risks.

5.1 Matter Controllers Comparison

5.1.1 Methodology. Because Matter encrypts all operational and data traffic, directly inspecting communication between a device and controller is challenging. To address this, we implemented a custom Matter test device based on the RGB lighting example from the Matter CHIP SDK [37]. The device was sequentially commissioned to four major ecosystems—Apple Home, Google Home, SmartThings, and Alexa. We captured and network traffic using tcpdump during commissioning and interactions (e.g., on/off, brightness, and color changes) and analyzed them in Wireshark to compare Matter behavior across the controllers.

5.1.2 Commissioning Workflow and Certification Handling. The Matter specification standardizes commissioning with strict security controls, including a 15-minute commissioning window, mandatory physical user action, and DAC verification before the device joins a fabric. Despite this standardized process, our experiments show that ecosystems differ noticeably in how they execute and log the commissioning workflow, revealing variations in practical implementation across platforms. Apple Home, Google Home, and SmartThings rely on the companion app (acting as Commissioner) to complete device onboarding, after which the controller manages the devices on the network. In contrast, Alexa often relies on Echo

devices acting as both Controller and Commissioner, allowing commissioning without a phone, though the standard phone-based QR code pairing via the Alexa app remains available.

Regarding certification enforcement, Matter allows vendors to reject uncertified devices, allow them with warnings, or permit them without restriction. In our experiments, all four ecosystems issued warnings when commissioning our uncertified Matter device, though the phrasing differed slightly: Apple Home, Google Home, and SmartThings displayed “The device is not certified,” while Alexa showed “The device is not Matter compatible.” Despite these warnings, all ecosystems accepted the uncertified device, indicating that certification enforcement is advisory in all four implementations.

5.1.3 Port Usage. Matter by default utilizes the IANA-assigned port 5540 (TCP and UDP) for commissioning and operational traffic, while permitting implementations to configure alternative ports when required [4]. Table 4 summarizes vendor-specific configurations observed across representative ecosystems. In a controlled testbed environment, we observed that Google Home operates on the default port 5540, Alexa was observed to use port 5541, and Apple Home and SmartThings employ dynamically assigned ports. Non-default port usage is supported through service discovery mechanisms such as mDNS, which advertise operational endpoints including port information, thereby supporting interoperability across heterogeneous deployments. These findings indicate that Matter port selection is primarily a vendor-specific implementation parameter rather than a security control mechanism.

5.1.4 Logging Verbosity. We observed significant differences in logging verbosity: Apple Home, Google Home, and SmartThings generate concise logs focused on essential operations, whereas Alexa produces more detailed logs capturing internal processes and configuration events. While verbose logging provides valuable diagnostic information, the security of sensitive data relies on the robustness of the Matter controller. Insufficient protection may allow detailed logs to reveal device behavior and system information, facilitating reconnaissance or targeted attacks. In contrast, selective logging may mitigate such exposure. Access to Matter operational logs in major smart-home ecosystems is restricted by cloud authentication and is not exposed through the Matter protocol, making cloud-account compromise the practical prerequisite for obtaining such logs rather than interception of encrypted Matter traffic.

5.1.5 Command Support and Feature Implementation. We observe that some Matter device libraries currently provide fewer features than those available through non-Matter apps or APIs, potentially limiting device functionality. For example, the SmartThings app did not display color options for the tested RGB light, despite the device supporting color control. This suggests gaps in feature discovery or UI implementation that may affect user experience, and users may be pushed toward vendor companion apps to access missing features, re-introducing proprietary communication paths with weaker privacy guarantees. We further evaluate support for Matter’s multi-admin functionality and find that all four controllers correctly implement it.

5.1.6 Key Findings. Certification enforcement is advisory across all controllers, allowing uncertified devices to join Matter fabrics. Alexa uniquely combines Controller and Commissioner roles and

Table 5: Inferred Matter Versions from Device Logs

Device	Inferred Version
3R Matter Bridge, Switchbot Bridge 2 Smartlife Bridge,	1.0 or 1.1 (ambiguous)
Matter Bulbs (Sengled, Tapo), Matter Plugs (Cync, Leviton, Meross, Moes, Tapo, Tuya), Govee Matter Strip,	1.1
Aqara Bridge M1, Aqara Bridge M2	1.2
Matter Bulbs (Sailsico, Consciot, Orein), Matter Plugs (Linkind Eightree) Matte Brigdes (Philips)	Unknown (insufficient data)

produces highly verbose logs, exposing additional operational metadata. Controllers that rely on the default port 5540 make Matter traffic trivially identifiable, reducing protocol-level anonymity. Finally, incomplete feature exposure in some controllers can push users toward vendor companion apps, reintroducing proprietary communication paths with weaker privacy guarantees.

5.2 Matter End-Devices Comparison

5.2.1 Methodology. Because Matter encrypts all unicast traffic, we employ the open-source, Matter-certified Home Assistant [19] as a centralized controller to observe and analyze device behavior. Each Matter device in the testbed (Table 3) was integrated with Home Assistant via QR code and comprehensive logging of network traffic during commissioning and routine operations (such as power control and color adjustments) was enabled. The logged traffic was analyzed to identify differences in Matter behavior across devices.

5.2.2 Matter Version Diversity. We inferred Matter versions by mapping captured ClusterRevision property values to the specification versions. For example, a Basic Information cluster reporting revision 2 indicates Matter version 1.2. However, firmware and hardware variations complicated this analysis. Early versions (1.0 and 1.1) share identical ClusterRevision values for several core clusters, making them indistinguishable from network traces alone. Additionally, some devices implement mixed attributes for backward compatibility. Table 5 summarizes the inferred versions across devices. Despite our efforts to allow updates, most devices continue to run older versions of the Matter specification, even though Matter 1.4 is the latest version available at the time of writing.

5.2.3 Protocol Implementation Variations. Table 6 highlights significant variations in Matter implementation across devices and manufacturers. MRP (Message Reliability Protocol) parameters support reliable UDP message delivery; some devices, such as Sengled and Orein bulbs, include them, while others do not.

We observe that Wi-Fi is the primary network used for Matter device commissioning. However, certain bridges (e.g., Aqara M1/M2 and Philips Bridge) do not support Wi-Fi-based commissioning and instead rely on wired Ethernet (IEEE 802.3) connections. Regulatory configuration support also differs: some TP-Link devices and bridges rely on built-in defaults, while others provide explicit configuration data.

Table 6: Analysis of Matter implementations across devices.
* Denotes devices upgraded to support Matter.

Matter Devices	MRP?	Wi-Fi Commis- sioning?	Regulatory config supplied?
TP-Link bulb	No	Yes	No (default device)
TP-Link Plug			
Plug (Tuya, Cync)	Yes		Yes
Bulb (Sengled, Orein, Consciot), Govee Strip, Plug (Meross, Moes, Linkind, Leviton*)			
Aqara Bridge M1*/ M2*, Philips Bridge*			
Smartlife Bridge	No	Not specified	No (default device)
Switchbot Bridge*, 3rd Reality Bridge		Yes	Yes

One device (Leviton plug) exhibits nonstandard command behavior; for example, the `MoveToLevelWithOnOff` command is used for basic on/off operations. This device received Matter support via a software update. These manufacturer-specific choices in feature support, parameter inclusion, and command implementation indicate that optional sections of the specification are interpreted differently, resulting in heterogeneous behavior that may impact interoperability, usability, and security. As these differences reflect implementation-specific choices rather than specification errors, they were excluded from the analysis.

5.2.4 Sensitive Information Handling. We analyzed the presence of sensitive information (device configurations, `SerialNumber`, `UniqueID`) in basic information messages. While these attributes are prevalent, their implementation is inconsistent. Transmitting extensive configurations may expose vulnerabilities, while transmitting *static* `uniqueID` enables device tracking. Notably, Meross devices do not rotate `UniqueID` even upon reset, contrary to the specification: “it SHALL be updated when the device is factory reset [4].” Matter implementation also varies in serial number handling: unlike other devices, Govee LED strips omit serial numbers for local communication, while TP-Link plugs use MAC addresses as serial numbers, increasing tracking risk.

5.2.5 Key Findings. Our analysis revealed substantial heterogeneity in Matter implementations across manufacturers. While devices nominally comply with the Matter specification, we identified significant variations in protocol implementation, including inconsistent MRP parameter usage, nonstandard command behaviors, and mixed cluster revision attributes. Privacy and security practices also vary considerably: some devices fail to rotate `UniqueID` upon reset (violating the specification), expose excessive device configurations, or use sensitive identifiers like MAC addresses as serial numbers. Another concern is that most Matter devices in our dataset still run early specification versions, despite having continuous Internet connectivity.

Table 7: Matter and Non-Matter Device Internet Destinations Second-Level Domains (SLDs).

Device	SLDs (Non-Matter)	SLDs (Matter)
TP-Link Bulb	tplinkcloud.com, tplinkra.com	tplinknbu.com
Sengled Bulb	sengled.com	amazon.com, amazonaws.com
TP-Link Plug	tplinkcloud.com, tplinkra.com	tplinknbu.com
Meross Plug	meross.com	meross.com
Tapo Plug	tplinkcloud.com	tplinknbu.com
Tuya Plug	tuya.com	N/A
Govee Strip	amazonaws.com, govee.com	govee.com

6 HYBRID-STACK MATTER DEVICES

This section answers RQ3: “What are the implications of supporting both the Matter protocol and vendor-specific legacy protocols on IoT devices?” While Matter is built to prioritize secure, encrypted local device control, many commercially available Matter devices implement hybrid architectures that support both Matter and proprietary protocols to maintain backward compatibility and enable vendor-specific features. Specifically, this section investigates whether these hybrid implementations compromise Matter’s core security and privacy guarantees. For a fair comparison, we focus on devices that offer both Matter and non-Matter versions from the same manufacturer with equivalent functionality.

6.1 Remote Destination Analysis

Although Matter is designed to support local communication without Internet connectivity, we observe that many Matter devices maintain active cloud connections. We systematically analyze all outbound Internet traffic to characterize these communication patterns and assess their implications for privacy and security.

6.1.1 Methodology. We captured and analyzed Internet-bound traffic from all Matter devices during initial commissioning via Matter (QR code/PIN), during normal operation under various ecosystems and re-commissioning via companion apps. For devices available in both Matter and non-Matter variants from the same manufacturer, we performed parallel analyses to identify differences in cloud communication patterns. The non-Matter devices were commissioned using companion apps. Traffic was captured using `tcpdump` and analyzed to extract second-level domains (SLDs).

6.1.2 Observations. Table 7 summarizes Internet destinations for paired Matter and non-Matter devices from identical manufacturers.

We observe three significant patterns.

Pattern 1: Matter devices connect to different vendor-controlled domains than their non-Matter counterparts. For example, TP-Link devices transition from legacy domains `tplinkcloud.com` and `tplinkra.com`, which support Kasa device control services, to `tplinknbu.com`, the backend endpoint for Matter-enabled Tapo devices. This change is consistent with product-line separation between Kasa and Tapo

rather than a fundamental change in cloud infrastructure requirements.

Pattern 2: Matter and non-Matter devices exhibit differing patterns in third-party domain usage. This behavior was observed across devices including TP-Link and Sengled bulbs, and TP-Link, Tapo, and Tuya smart plugs. For example, the Sengled bulb, non-Matter version of the device uses sengled.com, whereas the Matter version uses amazon.com and amazonaws.com, suggesting a potential migration from vendor-hosted infrastructure to third-party cloud services in Matter-enabled deployments.

Pattern 3: The commissioning method in hybrid-stack Matter devices determines the selected cloud endpoints. For example, devices such as the Govee Matter Strip and Leviton Matter Plug connect to Amazon Web Services only when onboarded via companion applications, not via Matter QR commissioning. This indicates that companion apps may trigger vendor-specific cloud services beyond the standard Matter protocol requirements.

6.1.3 Key Findings. These findings suggest that hybrid-stack implementations may weaken the intended privacy model of Matter, as users must rely on both vendor-managed infrastructure (e.g., TP-Link cloud services) and third-party ecosystem services (e.g., Google and Amazon) for functions such as voice control and automation synchronisation. Although Matter supports local-first communication, device commissioning via companion applications and account linking introduce additional cloud-mediated interactions.

6.2 Matter Devices Without Internet

We evaluate whether Matter devices remain controllable without Internet connectivity, as intended by the specification.

6.2.1 Methodology. Each Matter device was commissioned via its respective ecosystem and verified to be operational. We then isolated the local network from Internet connectivity using firewall rules while maintaining local Wi-Fi infrastructure. Device responsiveness was tested at three intervals: immediately after device reboot, one hour post-isolation, and eighteen hours post-isolation. For each test, we issued standard control commands (e.g., On/Off) and measured response latency and success rate.

6.2.2 Observations. Table 8 summarizes offline behavior across devices. Most devices operated reliably without Internet, confirming Matter’s local-first design. However, some devices experienced post-reboot delays, such as the Linkind plug (2s) and Cync plug (up to 30s), likely due to attempts to establish cloud connectivity during boot before enabling local operation. This may degrade user experience and suggests that certain vendors prioritize cloud-dependent initialization over local responsiveness, even when Matter operation should be self-contained.

6.2.3 Key Findings. Most Matter devices remain locally controllable without Internet, but some introduce cloud-dependent initialization routines that delay or disrupt responsiveness. Boot delays and intermittent failures show firmware assumes cloud-first operation, treating local-only operation as a fallback rather than the primary mode. In addition, even devices that are fully controllable offline still need Internet for firmware updates, unless they support

Table 8: Evaluation of Control Capabilities of Commercial Matter Devices Without Internet Access

Device	Controllable without Internet			
	Yes/ No	Post- Reboot	After 1 hr	After 18 hrs
Sengled bulb, Tapo plug, Meross plug	Yes	Yes (1/2)	Yes (1/2)	Yes
Linkind plug	Yes (2s delay)	Yes (2s delay)	Yes (2s delay)	Yes (2s delay)
Cync plug	Yes	Yes (30s delay)	Yes	Yes
Aqara Bridge	Some features work		Yes	Some features work
Rest devices and bridges	Yes	Yes	Yes	Yes

Table 9: Preferred Protocol for configuration with companion apps (Matter vs proprietary protocol)

Matter Device	Setup Method	Protocol Preference
Meross plug	Presents QR code	Matter
Tuya plug		Non-Matter
Sengled bulb	Incompatible with vendor app	
Other devices	Auto-add	Non-Matter

Matter OTA updates via controllers, which is necessary to achieve true cloud independence.

6.3 Companion App Protocol Preferences

Next, we investigate the protocol preferences of companion apps when configuring devices, i.e., whether they prioritize Matter or proprietary protocols.

6.3.1 Methodology. For each Matter-capable device with a companion app, we attempted device pairing exclusively through the manufacturer’s app (without using a controller app directly). We documented whether the app: (1) requested QR code scanning (indicating Matter commissioning), (2) used Bluetooth discovery without QR codes (indicating proprietary pairing), or (3) defaulted to non-Matter protocols despite Matter availability. We then verified the resulting communication protocol by analyzing network traffic.

6.3.2 Observations. Table 9 summarizes app pairing behaviors. The Meross app demonstrates best practice by requiring QR code scanning and automatically integrating devices with Apple Home using Matter protocols. This approach ensures users benefit from Matter’s security even when using manufacturer apps. Conversely, the Tuya Smart app prompts for QR code scanning but then defaults to non-Matter configuration, causing connection failures and inconsistent behavior. Other devices in our testbed were added automatically via Bluetooth discovery, without requiring a QR code for configuration. While this simplifies setup, it bypasses Matter

Table 10: Software Update Status of Smart Devices

Device	Firmware	Updated	1.0	1.1	1.2	1.3	1.4
Consciot bulb	3.00.00	Yes					✓
Cync plug	1.01.120						✓
Govee LED strip	1.01.03		✓				
Leviton plug	2.1.0		✓				
Linkind plug	1.00.00		✓				
Meross plug	9.3.26		✓				
Moes plug	1.2.6		✓				
Orein bulb	3.00.00	Yes					✓
Sengled bulb	1.0.0.5		✓				
Tapo bulb	1.3.0						✓
Tuya plug	1.0		✓				
Meross plug	9.3.26		✓				
Tapo plug	1.3.0	Yes				✓	
Eightree plug	1.2.6		α	α	α	α	α
Sailsco plug	1.2.6		α	α	α	α	α
Sengled-Plug	1.0.0.5		α	α	α	α	α
Xenon plug	1.2		α	α	α	α	α
Meross bridge	9.3.5				✓		
UseLink plug	1.2		α	α	α	α	α

α Certificate information not available from CSA.

integration and forces users into vendor-specific ecosystems with potentially weaker security. Note that the Sengled Matter Bulb is inherently incompatible with the Sengled app and must be added via a controller app.

6.3.3 Key Findings. Companion app design strongly affects whether users actually benefit from Matter capabilities. Apps that obscure or bypass Matter pairing effectively lock users into using less secure proprietary protocols, thereby undermining interoperability, privacy and security benefits of Matter. Without clear requirements for companion apps to present Matter pairing options, vendors can undermine the standard through interface design alone.

6.4 Firmware Update Practice

Timely firmware updates are critical for IoT device security. Matter evolved from Specification 1.0, defining core functionality, through 1.1–1.2 with key fixes and feature updates, to 1.3, expanding device support, and 1.4, adding optimizations and broader smart home compatibility.

6.4.1 Methodology. We analyzed firmware update status of 19 native Matter devices and 6 Matter bridges. Firmware versions were obtained through two methods: (1) a direct inspection of the ecosystem platform to view the device details that includes the firmware version, and (2) querying the Matter Distributed Compliance Ledger (DCL) to retrieve certification records based on the device Vendor and Product IDs. We recorded firmware versions at study initiation and after six months, checked companion apps for available updates, and compared current versions (as of Nov 2025) against initial release firmware from manufacturer documentation.

6.4.2 Observations. Certification metadata was available for 15 of 19 native Matter devices; the rest are not published, as CSA submission is optional.

As shown in Table 10, among the 19 Matter devices assessed, 8 devices (42%) are running firmware based on the Matter 1.0 specification, none are based on versions 1.1 or 1.2, 3 devices (15%) are on version 1.3, and 2 devices (10%) are running the latest 1.4 specification. During the observation period, only 3 of the 19 devices received firmware updates: Consciot and Orein bulbs were updated from 1.0 to 1.4, while Tapo devices progressed from 1.0 to 1.3. All remaining devices remained on their original firmware throughout the study.

Of the 6 Matter Bridges, 3 (50%) received updates. The higher update rate is likely due to higher device complexity, dual-protocol support, or an increased need for security patches, as Bridges face higher security exposure.

6.4.3 Key Findings. Our longitudinal assessment indicates limited firmware maintenance across commercial Matter deployments; most devices remain on factory-released software and only a minority receive post-deployment updates. This reveals a gap between operational practice and IoT lifecycle guidance in NIST IR 8259A and ETSI EN 303 645, which advocate timely security patching. However, Matter does not enforce structured update cadences or minimum patch obligations.

We note that certification-related information was not available for five devices in the dataset. In contrast, 50% of Matter bridges received updates during the study, likely driven by greater system complexity, dual-protocol operation, and increased security exposure.

7 RESILIENCE OF MATTER DEVICES

This section answers RQ4: “How resilient are Matter devices to realistic adversarial actions, such as unauthorized connection attempts and traffic-based inference?” While Matter strengthens baseline security with device attestation, authenticated commissioning, and end-to-end encryption, the ability to integrate devices into heterogeneous smart home networks inadvertently expands the attack surface. Specifically, this section evaluates the resilience of commercial Matter devices, particularly against adversaries attempting to perform replay attacks, initiate unauthorized connections, or infer user activity from observable metadata.

7.1 Adversary Types

We consider two realistic adversaries for consumer smart home deployments:

In-network adversary: An attacker on the local Wi-Fi network (e.g., a malicious guest) with no physical device access, and limited to observing local traffic, initiating unauthorized connections, or attempting replay attacks.

Proximity adversary: An attacker physically located within wireless range of the device (e.g., an outsider with a wireless sniffer) but without network access. This adversary can attempt unauthorized Bluetooth-based pairing with nearby devices or infer information from encrypted Wi-Fi traffic.

Excluded threats: We omit high-effort or impractical threats mentioned in the specifications [4], such as firmware modification or

malware insertion, private key extraction, supply-chain compromise, or visual capture of setup codes (e.g., via cameras). We assume all devices remain untampered and are configured according to vendor defaults.

7.2 Attacks

Prior research has shown several attacks on Matter, including weaknesses in PASE/CASE (particularly use of low-entropy passcodes, static salts, weak PBKDF2 parameters) [15] and physical-access attacks that enable extraction of DAC key via fault injection [24]. However, these attacks require physical access or specialized hardware and therefore fall outside our realistic threat model. In this study, we perform replay attacks, unauthorized pairing attacks, and passive inference attacks on all Matter end-devices, excluding Matter Bridges (as their behavior depends on the devices they connect).

7.2.1 Replay Attacks. In a replay attack an in-network adversary intercepts and retransmits valid messages to trick a system into performing unintended actions. Matter uses per-session message counters and timed interactions to protect against replay attacks [4], hence replay attacks were not successful against all our Matter devices.

7.2.2 Unauthorized Pairing Attacks. Matter requires commissioning windows to close after initial onboarding to prevent unauthorized pairing. Prior work has identified that AiDot-compatible devices are vulnerable to unauthorized pairing attacks, allowing adversaries to pair with already-commissioned devices via Bluetooth [34]. We evaluate whether AiDot-compatible devices remain vulnerable and whether other Matter devices exhibit similar weaknesses. For this, we commissioned each device with Matter controller by scanning the QR code, and attempted re-commissioning through the device's manufacturer app. We conducted this test from two adversarial positions: as an in-network adversary connected to the same local network, and as a proximity adversary outside the network but within Bluetooth range.

Our results show that AiDot-compatible devices (Linkind bulb, Orein bulb, Consciot bulb, and Linkind plug) still allow unauthorized pairing via the AiDot app, even when already commissioned via Matter. In contrast, all other Matter devices in our testbed correctly enforce protections by either closing the commissioning window or requiring physical access (button press, QR-code scan, or Wi-Fi password) to proceed with pairing.

7.2.3 Passive Inference Attacks. Although Matter encrypts payloads, metadata (e.g., packet sizes, timing, and multicast behavior) remains observable. To evaluate if we can infer any meaningful information from metadata, we passively captured Wi-Fi network traffic while triggering device events (e.g., On/Off) at least three times with a gap of 30 seconds. The captured sequences were then analyzed for recurring patterns and deviations across events.

Our results, summarized in Table 11, indicate that even encrypted traffic reveals detailed operational information. We observe a general traffic pattern for each device action (Off, On, Dim, Hue). For example, the Off event follows the sequence 121, 129, X, 96, 104, 96, Y, where the values denote operational packet sizes (in bytes) that are reproducible for a given device action, and X and Y are

device-specific substitutions that distinguish vendor behavior. For instance, the TP-Link Tapo bulb has X and Y values of 131 and 235, while the Sengled bulb has 158 and 158. All AiDot-compatible bulbs (from Linkind, Orein, and Consciot) exhibited identical traffic patterns, reflecting the possible use of the same underlying hardware across devices.

Furthermore, it was observed that bulbs typically include a Y value, whereas plugs do not. Unlike other plugs, the Leviton plug exhibits a Y-axis value in its traffic pattern. Since it was upgraded to Matter through an online firmware update rather than designed as a native Matter device, it incorrectly reports clusters that align with lighting behavior, resulting in the unexpected Y-value. Note that the packet sequence is usually consistent, with very rare instances where a packet may appear out of order due to device or network conditions.

Using these metadata patterns, we can distinguish bulbs from plugs with high reliability (approximately 94% in our dataset). Vendor identification is limited to 52.6%, as the MAC OUI often reveals only the chipset manufacturer (e.g., Espressif) rather than the actual device vendor. User state transitions, including On/Off, Dim, and color changes, can be inferred with reasonably high reliability. These results highlight that Matter's standardization produces consistent, predictable traffic patterns, enabling passive inference even without payload access.

7.2.4 Key Findings. All Matter devices in our study were resilient to replay attacks and unauthorized pairing attempts except those compatible with the AiDot platform, which remained pairable after Matter commissioning. This shows that Matter certification alone is not a guarantee of full resilience, as vendor-specific implementations can undermine required protections. Additionally, all evaluated devices were vulnerable to passive inference attacks that exploit predictable traffic patterns. Although payloads remain confidential, observable metadata reveals device type, vendor family, and user actions with high accuracy, indicating that Matter's encryption does not fully prevent side-channel leakage. Mitigations such as traffic shaping, padding, or aggregation at gateways are necessary to strengthen resistance to inference attacks.

8 DISCUSSION

Although Matter is designed as a security-focused framework [10], its real-world effectiveness is dependent on the manufacturer's implementation and adoption of the standard. Manufacturers have the discretion to determine aspects such as the level of service advertised via mDNS, which can impact security and privacy outcomes. Our evaluation suggests that simply adopting Matter does not inherently guarantee significantly improved security and privacy in IoT systems. In particular, some privacy challenges may not be fully addressed and can persist in Matter devices. Matter allows devices to function without Internet access or dedicated apps, improving user privacy, yet significant concerns remain about potential data exposure through network traffic and transmitted device commands.

Recommendations for Manufacturers. Matter device manufacturers should comply with the latest Matter specifications to ensure robust privacy and security practices. mDNS advertisements should be limited to those required for commissioning and operational discovery, avoiding unnecessary or persistent broadcasting beyond functional

Table 11: Passive Inference Attack on Matter Devices. The header row shows the packet sizes of the general event pattern shared across devices, while X and Y indicate device-specific substitutions within that pattern.

Devices	MAC OUI	Off	On	Dim	Hue
		121, 129, X, 96, 104, 96, Y	121, 129, X, 96, 104, 96, Y	133, 129, 132, 96, 104, 96, X	137, 130, X, 96, 104, 96, 121, 129
TP-Link bulb	Tp-Link	131, 235	235, 183	183	133
Sengled bulb	Espressif	158, 158	210, 158	158	133/ 188,
Linkind bulb	Espressif	210, -	210, 158	158	133
Orein bulb	Espressif	210, -	210, 158	158	133
Consciot bulb	Espressif	210, -	210, 158	158	133/ 188
Govee LED strip	Shenzhen	183, 183	235, 183	183	210/ 264/ 265
TpLink Tapo plug	Tp-Link	156, -	156, -	N/A	
Meross plug	Meross	156, -	156, -		
Eighttree plug	TuyaSmart	190, -	216, -		
Sengled plug	Espressif	183, -	209, -		
Sailsco plug	TuyaSmart	190, -	216, -		
Xenon plug	Espressif	183, -	209, -		
Moes plug	Tuya	163, -	163, -		
Tuya plug	Espressif	183, -	209, -		
Linkind plug	Espressif	158, -	184, -		
Cync plug	GELighting	183, -	209, -		
Leviton plug (Upgraded)	Leviton	133, 132	159, 131/ 157	158	N/A

requirements. Devices should employ rotating identifiers during normal operation to mitigate fingerprinting and inference attacks. Additionally, Matter devices should support timely and secure software updates to address emerging vulnerabilities. They should also provide users with the ability to disable privacy-sensitive features—for example, by turning off device name broadcasting—and offer options to disconnect devices from the Internet when appropriate. Support for software updates over the local network should also be required.

Recommendations for Standardization and Regulatory Bodies. Standardization bodies should consider mandating the use of the latest Matter versions along with well-defined privacy and security best practices for IoT devices. Currently, privacy and security guidelines are not clearly defined in any formal public Matter documentation. To address this gap, standardization bodies should collaborate with manufacturers, researchers, regulators, and other stakeholders to develop comprehensive guidelines for Matter-enabled IoT devices. Moreover, the certification process should be expanded to evaluate privacy-sensitive features—not merely verifying the correct implementation of the Matter protocol, but also ensuring that the protocol is used appropriately. Regulatory bodies should also consider requiring support for Matter or other local-only communication and local network software updates, thereby enhancing user privacy, security, and control over their devices.

Limitations. Our measurements cover 25 popular Wi-Fi/Ethernet based Matter devices available during the study period, and therefore do not represent all Matter-supported device categories; in particular. We exclude devices without direct access to the local Ethernet/Wi-Fi network or the Internet (e.g., Thread devices), since external control and data exposure are mediated by the Matter border router rather than the device itself. In such cases we analyze the Matter border router instead.

Device behavior may change as manufacturers release updates or adopt newer versions of the specification. Our analysis focuses on network-visible behavior and excludes hardware-level or physical-access attacks, which are outside our threat model. Finally, while we evaluate metadata exposure and identifier persistence, we do not analyze the contents of encrypted payloads. These limitations reflect the constraints of empirical measurement on commercial systems, but they do not affect the main findings of the study.

9 RELATED WORK

CSA has released essential resources to support development of Matter-compatible devices, including the Matter Core Specification [4], Matter Cluster Library [11], Matter Device Library Specification [12], and Matter SDK [13]. These frameworks equip developers with tools to implement secure and interoperable Matter devices.

Researchers have extensively investigated potential security and privacy vulnerabilities in Matter standard [27, 31, 35]. While these studies contribute significantly to understanding foundational security concerns, they predominantly focus on theoretical analyses rather than practical implementations.

To facilitate experimental research, Mangar et al. developed a testbed for the Matter protocol [29], that offers a controlled environment to assess the protocol. In practice, some studies demonstrate real-world vulnerabilities in Matter-enabled smart home systems [38], such as covert communication through hidden controllers [25], risks associated with delegation mechanisms [23], cryptographic flaws in Matter’s core protocols (PASE and CASE) [15], physical-access vulnerabilities allowing extraction of the DAC private key [24] and unauthorized access in AiDot devices [32, 34]. However, such studies have limited scope, focusing on specific scenarios or device types.

There is a pressing need for broader practical evaluations that encompass diverse devices, usage scenarios, and potential attack vectors. This will ensure robustness and reliability of Matter-enabled IoT and help uncover practical challenges and unforeseen vulnerabilities.

10 CONCLUSION

Our measurements show that Matter succeeds in providing a consistent security baseline for local communication. At the same time, our results highlight several limitations that affect deployed devices. First, Matter devices often expose identifying metadata through mDNS, retain long-lived identifiers, use EUI-64 derived IPv6 addresses, and exhibit predictable encrypted payloads. These practices allow reliable device fingerprinting and reveal basic information about user actions even when payloads remain encrypted. Second, hybrid Matter/non-Matter designs introduce cloud connectivity that is not covered by the Matter specification and that varies considerably across vendors. This introduces privacy risks that are independent of the Matter protocol. Third, vendor commissioning practices differ, and some devices still permit unauthorized pairing through manufacturer apps. Finally, firmware maintenance is inconsistent. Most devices operate on early Matter versions and did not receive updates during the study period. Taken together, these observations suggest that Matter improves several long-standing issues in IoT security, but its practical security and privacy properties depend heavily on vendor choices, and stronger adherence to the specification will be necessary if Matter is to deliver on its long-term goals.

To facilitate analysis and reproducibility at even larger scales, our experiment infrastructure, code, and data are publicly available at https://github.com/SafeNetIoT/matter_sec_privacy.

ACKNOWLEDGMENTS

The research presented in this paper was partially supported by the Engineering and Physical Sciences Research Council (EPSRC) under Grant EP/S022503/1, supporting the Centre for Doctoral Training in Cybersecurity delivered by University College London, and in part by the National Science Foundation under Grant No. 1955227 awarded to Northeastern University.

A ETHICS

This study adheres to established ethical guidelines to ensure responsible research practices. All IoT devices and mobile phones used in the experiments belong to the research team, with no unauthorized external connections. All the IoT devices and their apps were used according to their terms and conditions. Moreover, no user data was collected at any stage, maintaining full privacy and security compliance.

REFERENCES

- [1] Omar Alrawi, Chaz Lever, Manos Antonakakis, and Fabian Monrose. 2019. SoK: Security Evaluation of Home-Based IoT Deployments. In *2019 IEEE Symposium on Security and Privacy (SP)*. IEEE, San Francisco, CA, USA, 1362–1380. <https://doi.org/10.1109/SP.2019.00094>
- [2] Manos Antonakakis, Tim April, Michael Bailey, Matt Bernhard, Elie Bursztein, Jaime Cochran, Zakir Durumeric, J. Alex Halderman, Luca Invernizzi, Michalis Kallitsis, Deepak Kumar, Chaz Lever, Zane Ma, Joshua Mason, Damian Menscher, Chad Seaman, Nick Sullivan, Kurt Thomas, and Yi Zhou. 2017. Understanding the Mirai Botnet. In *26th USENIX Security Symposium (USENIX Security '17)*. USENIX Association, Vancouver, British Columbia, Canada, 1093–1110. <https://doi.org/10.1145/3241189.3241275>
- [3] Apple Inc. 2025. Set up your HomePod, HomePod mini or Apple TV as a home hub. <https://support.apple.com/en-gb/102557>. Accessed: 2025-11-10.
- [4] Connectivity Standards Alliance. [n. d.]. Matter Core Specification Version 1.3. <https://csa-iot.org/developer-resource/specifications-download-request/>. Accessed on May 11, 2024.
- [5] Connectivity Standards Alliance. 2023. *Why Bridging Matters*. <https://csa-iot.org/newsroom/why-bridging-matters/>. Accessed: 2025-11-10.
- [6] Connectivity Standards Alliance. 2024. *Matter 1.4 Enables More Capable Smart Homes*. <https://csa-iot.org/newsroom/matter-1-4-enables-more-capable-smart-homes/>. Accessed: 2025-11-10.
- [7] Connectivity Standards Alliance. 2025. Attestation. <https://handbook.buildwithmatter.com/how-it-works/attestation/>. Accessed: 2025-11-18.
- [8] Connectivity Standards Alliance. 2025. The Connectivity Standards Alliance Expands Board with CableLabs as Newest Promoter Member. <https://csa-iot.org/newsroom/the-connectivity-standards-alliance-expands-board-with-cablelabs-as-newest-promoter-member/>. Accessed: 2026-04-13.
- [9] Alissa Cooper, Fernando Gont, and Dave Thaler. 2016. Security and Privacy Considerations for IPv6 Address Generation Mechanisms. RFC 7721. <https://doi.org/10.17487/RFC7721>
- [10] CSA. 2022. Matter Security and Privacy Fundamentals. https://csa-iot.org/wp-content/uploads/2022/03/Matter_Security_and_Privacy_WP_March-2022.pdf.
- [11] CSA. 2023. *Matter Application Cluster Specification, Version 1.3*. Connectivity Standards Alliance (CSA), CA, USA.
- [12] CSA. 2023. *Matter Device Library Specification, Version 1.3*. Connectivity Standards Alliance (CSA), CA, USA.
- [13] CSA. 2024. Matter SDK. [Online]. Available: <https://github.com/project-chip/connectedhomeip>.
- [14] Daniel J Dubois, Roman Kolcun, Anna Maria Mandalari, Muhammad Talha Paracha, David Choffnes, and Hamed Haddadi. 2020. When speakers are all ears: Characterizing misactivations of iot smart speakers. *Proceedings on Privacy Enhancing Technologies* 2020, 4 (2020), 255–276.
- [15] Sayon Duttagupta, Arman Kolozyan, Georgio Nicolas, Bart Preneel, and Dave Singelee. 2025. What's the Matter? An In-Depth Security Analysis of the Matter Protocol. *IACR Cryptology ePrint Archive* 2025, 1268 (2025). Available at <https://dblp.org/rec/journals/iacr/DuttaguptaKNPS25.html>.
- [16] Aniketh Girish, Tianrui Hu, Vijay Prakash, Daniel J Dubois, Srdjan Matic, Danny Yuxing Huang, Serge Egelman, Joel Reardon, Juan Tapiador, David Choffnes, et al. 2023. In the Room Where It Happens: Characterizing Local Communication and Threats in Smart Homes. In *Proceedings of the 2023 ACM on Internet Measurement Conference*. ACM, Montreal, QC, Canada, 437–456.
- [17] Fernando Gont. 2014. A Method for Generating Semantically Opaque Interface Identifiers with IPv6 Stateless Address Autoconfiguration (SLAAC). RFC 7217. <https://doi.org/10.17487/RFC7217>
- [18] Google LLC. 2024. *Your Google Home Does More with Matter*. <https://home.google.com/get-inspired/matter-and-thread/>. Accessed: 2025-11-10.
- [19] Home Assistant Contributors. 2025. Home Assistant — Open source home automation that puts local control and privacy first. <https://www.home-assistant.io/>. Accessed: 2025-11-08.
- [20] Tianrui Hu, Daniel J Dubois, and David Choffnes. 2023. Behavior: Measuring smart home iot behavior using network-inferred behavior models. In *Proceedings of the 2023 ACM on Internet Measurement Conference*. ACM, Montreal, QC, Canada, 421–436.
- [21] Tianrui Hu, Daniel J Dubois, and David Choffnes. 2024. IoT Bricks Over v6: Understanding IPv6 Usage in Smart Homes. In *Proceedings of the 2024 ACM on Internet Measurement Conference*. ACM, Madrid, Spain, 595–611.
- [22] Umar Iqbal, Pounh Nikkiah Bahrami, Rahmadi Trimnanda, Hao Cui, Alexander Gamero-Garrido, Daniel J. Dubois, David Choffnes, Athina Markopoulou, Franziska Roesner, and Zubair Shafiq. 2023. Tracking, Profiling, and Ad Targeting in the Alexa Echo Smart Speaker Ecosystem. In *Proceedings of the 2023 ACM Internet Measurement Conference (IMC '23)*. ACM, Montreal, QC, Canada, 569–583. <https://doi.org/10.1145/3618257.3624803>
- [23] Z. Jin, Y. Fang, H. Wang, K. Chen, Q. Liu, and L. Xing. 2024. Delegation Related Privacy Issues in Matter. In *Workshop on Security and Privacy in Standardized IoT (SDIoTSec)*. Internet Society, San Diego, CA, USA.
- [24] Nozomi Networks Labs. 2024. *Trust Matters: Attacking Smart Device Authenticity*. Technical Report. Nozomi Networks Labs. White paper. Available online at: https://cdn.prod.website-files.com/645a4534705010e2cb244f50/6735a605604f09e9d61a37a9_Nozomi-Networks-WP-Trust-Matters-Attacking-Smart-Device-Authenticity.pdf.
- [25] S. Liao, J.Yan, and L. Cheng. 2024. WIP: Hidden Hub Eavesdropping Attack in Matter-enabled Smart Home Systems. In *Workshop on Security and Privacy in Standardized IoT (SDIoTSec)*. Internet Society, San Diego, CA, USA. <https://doi.org/10.14722/sdiotsec.2024.23089>
- [26] Haoyu Liu, Tom Spink, and Paul Patras. 2019. Uncovering security vulnerabilities in the Belkin WeMo home automation ecosystem. In *2019 IEEE International Conference on Pervasive Computing and Communications Workshops (PerCom)*

- Workshops). IEEE, Kyoto, Japan, 894–899. <https://doi.org/10.1109/PerComW.2019.8730780>
- [27] M. Loos. 2023. Security Analysis of the Matter Protocol. [Online]. Available: https://oparu.uni-ulm.de/xmlui/bitstream/handle/123456789/49010/Matter_MLO2023.pdf?sequence=5.
- [28] Anna Maria Mandalari, Daniel J. Dubois, Roman Kolcun, Muhammad Talha Paracha, Hamed Haddadi, and David Choffnes. 2021. Blocking Without Breaking: Identification and Mitigation of Non-Essential IoT Traffic. *Proceedings on Privacy Enhancing Technologies (PoPETs) 2021*, 4 (2021), 369–388. <https://doi.org/10.2478/popets-2021-0075>
- [29] R. Mangar, J. Qian, W. Zegeye, A. AlRabah, B. Civjan, S. Sundram, S. Yuan, C.A. Gunter, M. Khanafer, K. Kornegay, T.J. Pierson, and D. Kotz. 2024. Designing and Evaluating a Testbed for the Matter Protocol: Insights into User Experience. In *Proceedings of the NDSS Workshop on Security and Privacy in Standardized IoT (SDIoTSec 2024)*. Internet Society, San Diego, CA, USA. <https://doi.org/10.14722/sdiotsec.2024.23012>
- [30] Jingjing Ren, Daniel J. Dubois, David Choffnes, Anna Maria Mandalari, Roman Kolcun, and Hamed Haddadi. 2019. Information Exposure for Consumer IoT Devices: A Multidimensional, Network-Informed Measurement Approach. In *Proceedings of the 2019 ACM Internet Measurement Conference (IMC '19)*. ACM, Amsterdam, Netherlands, 267–279. <https://doi.org/10.1145/3355369.3355577>
- [31] Schutzwert. 2023. Security Considerations for Matter Developers. [Online]. Available: <https://www.schutzwert.com/en/blog/matter-security-considerations/>.
- [32] Narmeen Shafqat. 2024. *Privacy Attacks and Defenses in the IoT and Mobile Ecosystems*. PhD dissertation. Northeastern University. <https://www.proquest.com/openview/123c0fa965db0a3d4643599be33393fd/1?pq-origsite=gscholar&cbl=18750&diss=y> ProQuest Dissertations & Theses Global.
- [33] Narmeen Shafqat, Daniel J. Dubois, David Choffnes, Aaron Schulman, Dinesh Bharadia, and Aanjan Ranganathan. 2022. Zleaks: Passive inference attacks on Zigbee based smart homes. In *International Conference on Applied Cryptography and Network Security*. Springer, 105–125.
- [34] N. Shafqat and A. Ranganathan. 2024. Seamlessly Insecure: Uncovering Outsider Access Risks in AiDot-Controlled Matter Devices. In *IEEE Security and Privacy Workshops (SPW), SafeThings*. IEEE, San Francisco, CA, USA.
- [35] S. Singh. 2023. Intercompatibility of IoT Devices Using Matter: Next-Generation IoT Connectivity Protocol. In *International Conference on Advances in IoT and Security with AI*. Springer, New Delhi, India, 49–58.
- [36] SmartThings. 2023. Works with SmartThings. <https://www.smartthings.com/works-with-smartthings>. [Online].
- [37] Project CHIP Team. 2025. policy, procedures, code: connectedhomeip repository. GitHub repository. <https://github.com/project-chip/connectedhomeip> Accessed: 2025-11-12.
- [38] H. Wang, Y. Liu, Y. Fang, Z. Jin, Q. Liu, and L. Xing. 2024. Security Vulnerabilities and Attack Scenarios in Smart Home with Matter. In *Workshop on Security and Privacy in Standardized IoT (SDIoTSec)*. IEEE, San Diego, CA, USA, 1–5.
- [39] Wei Zhou, Yan Jia, Yao Yao, Lipeng Zhu, Le Guan, Yuhang Mao, Peng Liu, and Yuqing Zhang. 2019. Discovering and Understanding the Security Hazards in the Interactions between IoT Devices, Mobile Apps, and Clouds on Smart Home Platforms. In *28th USENIX Security Symposium (USENIX Security 19)*. USENIX Association.